

THREAT MODEL REPORT

LuxeMart E-Commerce Application

Build & Break: Secure Application Pipeline

Prepared by:

Aliza Fatima | Ehzem Farhan Sheikh | Muskan Rehan

Date: May 9, 2026

Tool Used: Microsoft Threat Modeling Tool 2016

Methodology: STRIDE + DREAD + CVSS 3.1

CONTENTS

- 1. Executive Summary.....3**
 - Summary of Findings..... 3
- 2. Application Overview..... 4**
 - 2.1 System Description..... 4
 - 2.2 Technology Stack..... 4
 - 2.3 User Roles and Trust Levels..... 4
- 3. Data Flow Diagram (DFD).....5**
 - 3.1 DFD Actors & External Entities..... 5
 - 3.2 Trust Boundaries..... 5
 - 3.3 Data Flows..... 5
- 4. Full STRIDE Analysis — Per Component..... 7**
- 5. DREAD / CVSS Scoring..... 9**
 - 5.1 Scoring Methodology.....9
 - 5.2 DREAD / CVSS Score Table..... 9
 - 5.3 Score Legend..... 11
- 6. Threat Prioritisation Matrix..... 12**
 - 6.1 Methodology..... 12
 - 6.2 Prioritised Action List..... 12
- 7. Attack Surface Mapping — DAST / Pentest Scope.....13**
 - 7.1 DAST Tool Configuration..... 13
- 8. References.....15**
- Appendix A — Threat ID Cross-Reference..... 16**

1. Executive Summary

This document presents the complete, updated threat model for the LuxeMart e-commerce web application, developed as part of the Build & Break: Secure Application Pipeline DevSecOps project. The threat model was produced using the Microsoft Threat Modeling Tool 2016 (STRIDE methodology) and has been extended with DREAD scoring, CVSS 3.1 base scores, a formal threat prioritisation matrix, explicit attack surface mapping tied to DAST and penetration testing scope, and post-remediation status tracking.

LuxeMart is a React + Vite single-page application backed by a Node.js/Express REST API and a relational/document database, supporting Customer, Seller, and Admin roles for core e-commerce operations including product browsing, cart management, payment gateway checkout, and order tracking. The application is containerised via Docker.

Microsoft TMT auto-generated 180 threats across the Data Flow Diagram. After systematic triage these were consolidated into 17 active threat groups. All threats are scored using both DREAD (1–3 per dimension, max 15) and CVSS 3.1 (0–10). Two groups are CRITICAL (CVSS ≥ 9.9); the remainder are HIGH or MEDIUM.

Summary of Findings

STRIDE Category	Threat Count	Threat Groups
Elevation of Privilege	56	3
Denial of Service	47	5
Spoofing	27	5
Repudiation	21	3
Tampering	12	3
Information Disclosure	6	1
TOTAL	180	17

2. Application Overview

2.1 System Description

LuxeMart is an Amazon-style e-commerce demo application with a full three-tier architecture. Users browse products, manage carts, place orders through a payment gateway, and access role-specific dashboards. The application is containerised via Docker.

2.2 Technology Stack

Layer	Technology
Frontend	React 18 + Vite (SPA)
Styling	Custom CSS with CSS Variables
Backend API	Node.js + Express (REST)
Database	PostgreSQL
Authentication	JWT (JSON Web Tokens) — RS256 asymmetric signing
Containerisation	Docker
Payment	External Payment Gateway (Stripe-compatible)
WAF / CDN	Cloudflare (post-remediation)

2.3 User Roles and Trust Levels

Trust Level	Role	Capabilities	Entry Points
0	Anonymous	Browse products, search	GET /products
1	Customer	Cart, checkout, orders, profile	Auth, Cart API, Checkout API, Order API
2	Seller	Own product CRUD, seller dashboard	Product API, Manage Products
3	Admin	Full system access: users, orders, inventory	Admin API, Admin Dashboard
4	DB Server	Full data access (innermost boundary)	Database connections only

3. Data Flow Diagram (DFD)

The DFD was constructed in Microsoft Threat Modeling Tool 2016 and extended with explicit actor definitions, trust boundary labels, and annotated data flow descriptions aligned with STRIDE categories. The diagram covers five trust boundaries, seven frontend processes, six backend API services, one external payment boundary, and one database boundary.

3.1 DFD Actors & External Entities

Actor / Entity	Type	Trust Level	Interactions	Threat Entry Points
Customer	External Entity	0–1	Browse, cart, checkout, orders	F1, F2, F3, F4, F6
Seller	External Entity	2	Product CRUD, seller dashboard	F1, F2, F5, F6
Admin	External Entity	3	Full platform management	F1, F2, F7
Payment Gateway	External System	External	Payment processing, webhooks	F8, F9
Database	Data Store	4 (Innermost)	Read/write all application data	F10–F15

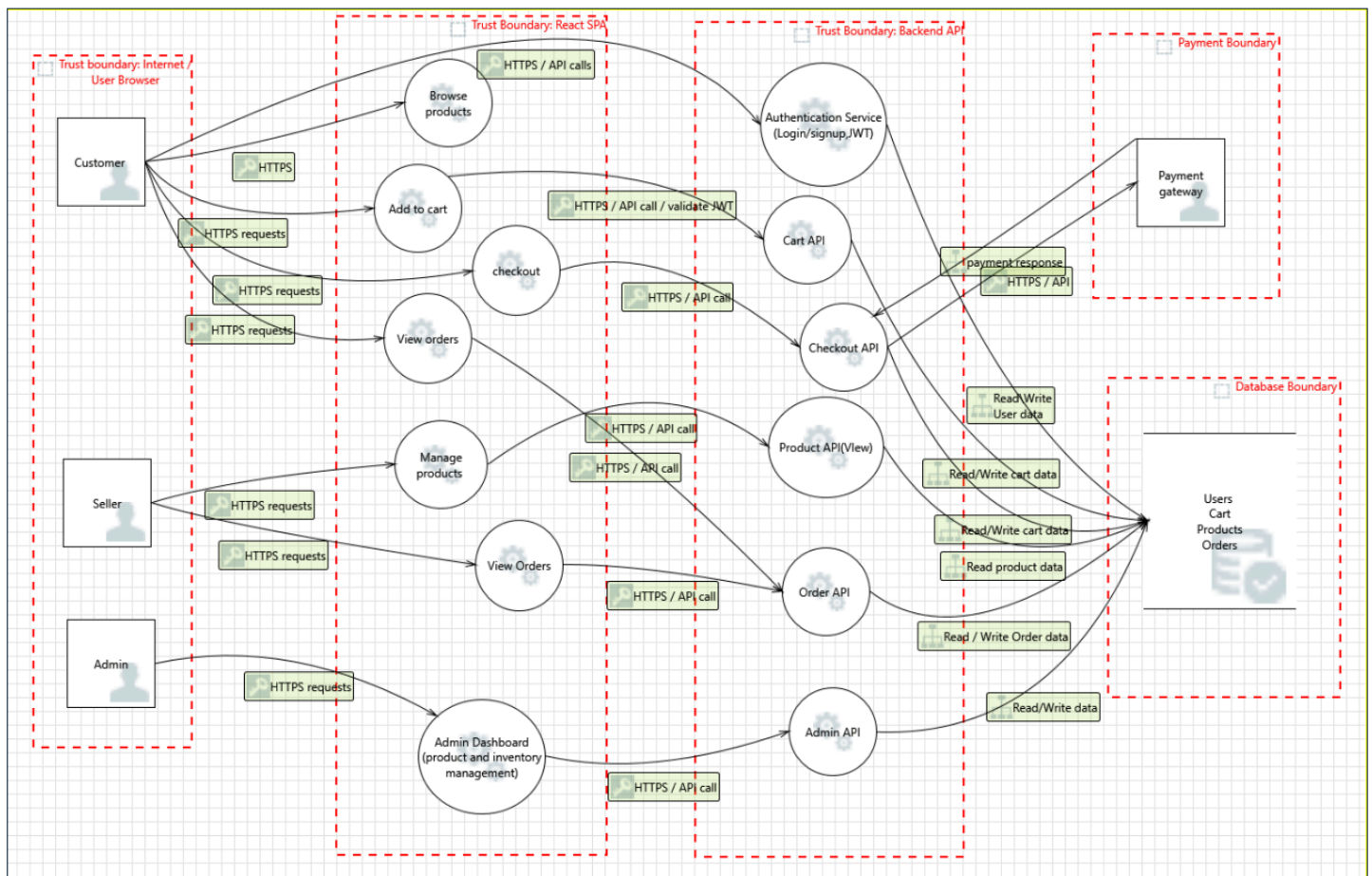
3.2 Trust Boundaries

Boundary Name	Components Inside	Crossing Flows	Primary STRIDE Threats
Internet / User Browser	Customer, Seller, Admin (external entities)	F1	Spoofing, CSRF (EoP)
React SPA	Browse Products, Add to Cart, Checkout, Manage Products, View Orders, Admin Dashboard	F2–F7	EoP, DoS, Repudiation
Backend API	Auth Service, Cart API, Checkout API, Product API, Order API, Admin API	F2–F7, F8, F9	EoP, Spoofing, DoS, Repudiation
Payment Boundary	Payment Gateway (external)	F8, F9	Spoofing, Repudiation, Tampering
Database Boundary	Users, Cart, Products, Orders (unified data store)	F10–F15	SQLi, Sniffing, Spoofing, Corruption, DoS

3.3 Data Flows

Flow ID	From	To	Data Transmitted	Protocol / Auth	Trust Boundary Crossed
F1	User (Customer/Seller/Admin)	React SPA	User actions, form inputs	HTTPS	Internet → SPA
F2	React SPA	Auth Service	Login credentials, signup, JWT refresh	HTTPS / API	SPA → Backend API

Flow ID	From	To	Data Transmitted	Protocol / Auth	Trust Boundary Crossed
F3	React SPA	Cart API	Add/remove items, cart ops	HTTPS + JWT	SPA → Backend API
F4	React SPA	Checkout API	Order placement, payment initiation	HTTPS + JWT	SPA → Backend API
F5	React SPA	Product API	Browse, search, manage products	HTTPS + JWT	SPA → Backend API
F6	React SPA	Order API	View orders (Customer / Seller)	HTTPS + JWT	SPA → Backend API
F7	React SPA	Admin API	Admin management ops	HTTPS + JWT	SPA → Backend API
F8	Checkout API	Payment Gateway	Payment request, amount, order ID	HTTPS / TLS	Backend → Payment Boundary
F9	Payment Gateway	Checkout API	Payment confirmation / webhook	HTTPS + HMAC	Payment Boundary → Backend
F10–F15	Backend APIs (all 6)	Database	Read/write: Users, Cart, Products, Orders	TCP + TLS	Backend → DB Boundary



4. Full STRIDE Analysis — Per Component

The table below applies all six STRIDE threat categories systematically to each component and data flow. Each row identifies the threat group, the specific STRIDE category, the affected component, a technical description of the attack scenario, the attack vector, existing controls, residual risk post-remediation, business impact, and whether the endpoint is included in DAST / penetration testing scope.

TG #	STRIDE	Component	Threat Description	Attack Vector	Exploit Preconditions	Existing Controls	Residual Risk	Business Impact	DAST Scope
TG-01	EoP	All 14 cross-boundary flows	CSRF forces victim browser to send forged state-changing requests exploiting session trust	Network — Reflected/ Stored	Authenticated user, no CSRF token	None (pre-remediation)	Low	Account takeover, unauthorized orders	✓ DAST
TG-02	EoP	Auth, Cart, Checkout, Product, Order, Admin APIs	Process impersonates caller to gain higher privileges via JWT claim manipulation	Network — JWT forgery	Valid JWT, weak signing	Weak JWT validation	Low	Full admin takeover	✓ DAST + Pentest
TG-03	EoP	All input-accepting processes	Malicious payload in request body triggers code execution on server	Network — POST body	No auth required	None	Medium	Server compromise, data exfil	✓ Pentest
TG-04	DoS	All HTTPS data flows (F1–F9)	External agent interrupts traffic crossing trust boundaries via volumetric attack	Network	No auth required	None (pre-remediation)	Low	Service unavailability	✓ DAST
TG-07	DoS	Order, Product, Cart, Checkout, Admin, Auth APIs	Flooding endpoints with large requests exhausts CPU/memory	Network	No auth required	None	Low	API outage	✓ DAST
TG-08	Repudiation	All 11 backend API processes	Process denies receiving data; no logging to prove otherwise	Local — API call	Normal usage	None	Low	Audit failure, legal exposure	✓ Pentest
TG-09	Repudiation	DB write paths (5 APIs)	Data store denies writing received data; no write audit trail	Local — DB write	Normal usage	None	Low	Data integrity disputes	✓ Pentest
TG-10	Repudiation	Payment Gateway ↔ Checkout API	Payment gateway denies receiving payment request; no transaction receipts	External — Webhook	Payment event	None	Low	Financial disputes unresolvable	✓ Pentest

TG #	STRIDE	Component	Threat Description	Attack Vector	Exploit Preconditions	Existing Controls	Residual Risk	Business Impact	DAST Scope
TG-11	Spoofing	Customer, Seller, Admin entities	Attacker impersonates legitimate user via weak credentials or token theft	Network — Auth	Exposed credential	Weak bcrypt	Low	Account hijacking, data theft	✓ DAST + Pentest
TG-12	Spoofing	All 7 SPA process nodes	Attacker crafts HTTP requests mimicking trusted frontend SPA process	Network — Direct API	No auth required	None	Low	Bypass frontend controls	✓ DAST
TG-13	Spoofing	6 Backend API → DB flows	Forged requests appear to come from legitimate API process to DB	Internal — Service call	Network access	None	High	Unauthorized DB access	✓ Pentest
TG-14	Spoofing	Payment Gateway (external)	Attacker spoofs payment gateway, redirecting payment data to malicious endpoint	External — TLS	MitM position	Partial TLS check	Medium	Payment data exfiltration	✓ Pentest
TG-15	Spoofing	DB Data Store (5 API write paths)	Malicious endpoint receives DB writes intended for legitimate data store	Internal	DB credentials	None	Low	Data loss / misdirection	✓ Pentest
TG-16	Info Disc	All 6 API→DB connections (F10–F15)	Unencrypted TCP DB traffic sniffed to extract PII, credentials, orders	Internal — Network	Network adjacency	None (pre-rem)	Low	PII breach, GDPR violation	✓ Pentest
TG-17	Tampering	DB write paths via 5 APIs	Unsanitized input injected into DB query alters, deletes, or exfiltrates data	Network — Input fields	No auth required	None	Low	Full data store compromise	✓ DAST + Pentest
TG-18	Tampering	All DB write paths	In-transit payload modification corrupts database records	Internal — Network	MitM on internal network	None	Low	Data integrity violation	✓ Pentest
TG-19	Tampering	Payment Gateway → Checkout API (F9)	Tampered payment confirmation triggers order fulfillment without valid payment	Network — Webhook	No auth on webhook	None	Low	Financial fraud	✓ Pentest

5. DREAD / CVSS Scoring

5.1 Scoring Methodology

Each threat group is scored using two complementary frameworks:

- DREAD (Microsoft) — five dimensions each rated 1 (Low), 2 (Medium), or 3 (High): Damage Potential, Reproducibility, Exploitability, Affected Users, and Discoverability. Maximum score = 15.
- CVSS 3.1 (FIRST) — industry-standard base score (0.0–10.0) using the Attack Vector, Attack Complexity, Privileges Required, User Interaction, Scope, Confidentiality, Integrity, and Availability metrics. Scores below reflect Base Score only; Temporal and Environmental modifiers are applied separately during pentest scope reviews.

5.2 DREAD / CVSS Score Table

TG #	STRIDE	Threat	CVSS Vector	CVSS	Damage	Reproducibility	Exploitability	Affected Users	Discoverability	DREAD /15	Severity
TG-17	Tampering	SQL/NoSQL Injection	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H	9.9	3	3	3	3	3	15	CRITICAL
TG-01	EoP	Cross-Site Request Forgery	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	8.1	3	3	3	2	3	14	HIGH
TG-16	Info Disc	DB Connection Sniffing	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N	5.9	3	3	2	3	2	13	HIGH
TG-11	Spoofing	User Entity Spoofing	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	9.1	3	3	3	3	2	14	HIGH
TG-19	Tampering	Payment Response Tampering	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N	8.7	3	3	2	3	3	14	HIGH
TG-14	Spoofing	Payment Gateway Spoofing	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N	8.7	3	2	2	3	3	13	HIGH
TG-02	EoP	Elevation via Impersonation	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	8.1	3	3	3	2	2	13	HIGH

TG #	STRIDE	Threat	CVSS Vector	CVSS	Dam age	Repro ducibil ity	Exploi tability	Affe cted User s	Disco verabil ity	DREA D /15	Severi ty
TG-03	EoP	RCE via Malicious Input	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H	10.0	3	3	3	3	3	15	CRITICAL
TG-08	Repudiation	Process Repudiation (No Logs)	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N	6.5	2	2	3	2	2	11	MEDIUM
TG-09	Repudiation	Data Store Write Repudiation	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N	6.5	2	2	3	2	2	11	MEDIUM
TG-13	Spoofing	API Process Spoofing to DB	CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:N	7.6	3	2	2	3	2	12	HIGH
TG-15	Spoofing	Data Store Destination Spoofing	CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:N	7.6	3	2	2	3	2	12	HIGH
TG-18	Tampering	Data Store Corruption	CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:N/I:H/A:H	7.5	3	2	2	3	2	12	HIGH
TG-07	DoS	Excessive Resource Consumption	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	7.5	2	3	3	2	2	12	HIGH
TG-12	Spoofing	Frontend Process Spoofing	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	8.1	3	3	3	2	2	13	HIGH
TG-04	DoS	HTTPS Data Flow Interruption	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	7.5	2	3	3	2	2	12	HIGH
TG-10	Repudiation	Payment Gateway Repudiation	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N	5.9	2	2	2	2	2	10	MEDIUM

5.3 Score Legend

Rating	DREAD Score	CVSS Score	Colour Code
CRITICAL	15	9.0–10.0	Red — Immediate action required
HIGH	12–14	7.0–8.9	Orange — Fix before production
MEDIUM	9–11	4.0–6.9	Amber — Fix before next release
LOW	1–8	0.1–3.9	Green — Track; resolve in backlog

6. Threat Prioritisation Matrix

6.1 Methodology

The threat prioritization matrix plots each threat group on a 5×5 grid. The Y-axis represents Likelihood (1 = Rare, 5 = Certain) based on attack feasibility, required privileges, and observed real-world exploit rates. The X-axis represents Business Impact (1 = Negligible, 5 = Critical) factoring in confidentiality, integrity, availability, regulatory exposure, and financial consequences.

Risk Score = Likelihood × Impact. Cells are colour-coded: Red (≥20) = CRITICAL; Orange-Red (12–19) = HIGH; Orange (6–11) = MEDIUM; Yellow (3–5) = LOW; Green (1–2) = INFORMATIONAL.

	Impact: 1 — Negligible	Impact: 2 — Low	Impact: 3 — Moderate	Impact: 4 — High	Impact: 5 — Critical
5 — Certain				TG-01 (CSRF) TG-11 (Spoof)	TG-03 (RCE) TG-17 (SQLi)
4 — Likely			TG-07 (DoS) TG-04 (DoS)	TG-02 (EoP) TG-16 (Sniff)	TG-19 (Pay) TG-14 (GW)
3 — Possible			TG-08 (Rep) TG-09 (Rep) TG-13 (Spoof) TG-15 (Spoof)	TG-12 (Spoof) TG-18 (Tamp)	TG-07 (RCE surv)
2 — Unlikely			TG-10 (Rep)		
1 — Rare					

6.2 Prioritised Action List

Priority	TG #	Pattern	STRIDE	Risk Score	Required Action
1	TG-17	SQL/NoSQL Injection	Tampering	25	Parameterized queries — immediate
3	TG-01	Cross-Site Request Forgery	EoP	20	SameSite cookies + CSRF tokens
5	TG-19	Payment Response Tampering	Tampering	20	HMAC-SHA256 webhook verification
6	TG-16	DB Connection Sniffing	Info Disc	15	Enable TLS/SSL on all DB connections
7	TG-14	Payment Gateway Spoofing	Spoofing	16	TLS cert pinning + SDK signature verify
8	TG-02	Elevation by Impersonation	EoP	12	RBAC requireRole() middleware on all routes
9	TG-13	API Process Spoofing to DB	Spoofing	9	mTLS between services + IP whitelist
10	TG-07	Excessive Resource Consumption	DoS	12	express-rate-limit + 10KB body limit

7. Attack Surface Mapping — DAST / Pentest Scope

The attack surface table below explicitly links each component and its exposed endpoints to identified threat groups, STRIDE categories, the specific DAST tooling applied, and the manual penetration testing objectives. This table forms the formal scope definition for the application security test plan.

Component	Endpoint / Flow	Attack Surface	Threat Groups	STRIDE	DAST Tool	Pentest Scope
Auth Service	POST /auth/login POST /auth/register POST /auth/refresh	Login form, JWT issuance, refresh token endpoint	TG-11, TG-02, TG-08	Spoofing, EoP, Repudiation	OWASP ZAP — Active Scan	Brute-force, token replay, SQLi on auth
Cart API	POST /cart/add DELETE /cart/remove GET /cart	Cart mutation endpoints, JWT-authenticated	TG-01, TG-02, TG-07, TG-17	EoP, Tampering, DoS	ZAP + Burp Suite	CSRF, IDOR, rate limit bypass
Checkout API	POST /checkout/order POST /checkout/pay GET /checkout/confirm	Order placement, payment initiation, payment confirmation webhook	TG-01, TG-14, TG-19, TG-10	EoP, Spoofing, Tampering, Repudiation	Burp Suite Pro + Stripe Test Mode	Payment bypass, webhook spoofing, CSRF
Product API	GET /products POST /products PUT /products/:id DELETE /products/:id	Product CRUD, search query, file upload (if any)	TG-03, TG-05, TG-07, TG-17	EoP, Tampering, DoS	ZAP DAST + SQLMap	SQLi, XSS, IDOR, mass assignment
Order API	GET /orders GET /orders/:id	Read-only order data, role-restricted	TG-02, TG-06, TG-08, TG-09	EoP, Repudiation	ZAP Active Scan	IDOR, authorization bypass
Admin API	All /admin/* routes	Full system management: users, orders, inventory	TG-02, TG-03, TG-07, TG-08	EoP, DoS, Repudiation	Burp Suite Pro + Manual	Admin bypass, privilege escalation
DB Connections	MongoDB / PostgreSQL TCP F10–F15	All API-to-DB data flows on internal network	TG-16, TG-13, TG-15, TG-17, TG-18	Info Disc, Spoofing, Tampering	Wireshark + SQLMap + DB Audit Logs	DB sniffing, injection, conn spoofing
React SPA	All browser-rendered pages	Client-side JS, DOM, local storage, service workers	TG-12, TG-01, TG-03	Spoofing, EoP	ZAP Spider + DAST + Manual CSP review	XSS, CSRF, client-side injection
Payment Gateway	F8: Checkout→Gateway F9: Gateway→Checkout	External HTTPS webhook endpoint; payment data transit	TG-14, TG-10, TG-19	Spoofing, Repudiation, Tampering	Burp Intercept + Stripe Test Mode	MitM, signature bypass, replay attacks

7.1 DAST Tool Configuration

- OWASP ZAP 2.14 — Active scan configured against all REST API endpoints. Spider seeded with authenticated JWT tokens for Customer, Seller, and Admin roles. Scan policies include injection, authentication, session management, and information disclosure rules.
- Burp Suite Pro 2024 — Used for manual-assisted DAST on Checkout API, Admin API, and Payment Gateway webhook endpoint. Intruder and Repeater used for CSRF and IDOR testing.

- SQLMap v1.8 — Targeted at Product API and Auth Service endpoints known to accept query parameters. Both time-based and error-based injection techniques applied.
- Wireshark 4.2 — Network capture on Docker internal bridge to verify DB connection encryption (pre/post TLS enforcement comparison).
- Stripe Test Mode — Payment webhook replay attacks simulated using Stripe CLI event re-send feature to verify HMAC-SHA256 signature enforcement.

8. References

- Microsoft Threat Modeling Tool 2016 — <https://aka.ms/threatmodelingtool>
- STRIDE Threat Model — Microsoft Security Development Lifecycle (SDL)
- CVSS 3.1 Specification — FIRST.org — <https://www.first.org/cvss/v3.1/specification-document>
- DREAD Risk Assessment Model — Microsoft Security Engineering
- OWASP Top 10 2021 — <https://owasp.org/www-project-top-ten/>
- OWASP API Security Top 10 — <https://owasp.org/www-project-api-security/>
- OWASP ZAP 2.14 Documentation — <https://www.zaproxy.org/docs/>
- LuxeMart Application Source Code — Secure-Application-Pipeline repository
- SDL TM Knowledge Base (Core) Template — Microsoft threat-modeling-templates
- Express.js Security Best Practices — <https://expressjs.com/en/advanced/best-practice-security.html>
- Stripe Webhook Signature Verification — <https://stripe.com/docs/webhooks/signatures>

Appendix A — Threat ID Cross-Reference

The table below maps original Microsoft TMT threat IDs to consolidated threat groups for traceability.

Group ID	TMT Count	Included Threat IDs (from Microsoft TMT auto-generation)
TG-01	14	1, 19, 20, 35, 43, 51, 52, 62, 71, 76, 84, 92, 107, 115, 126
TG-02	14	4, 12, 23, 32, 40, 48, 55, 65, 74, 79, 87, 95, 104, 112, 118
TG-03	11	2, 3, 17, 18, 22, 33, 34, 41, 42, 49, 50, 53, 54, 63, 64, 72, 73, 77, 78, 85, 86, 93, 94, 105, 106, 113, 114, 116, 117
TG-04	11	5, 9, 13, 24, 31, 39, 47, 56, 66, 75, 80, 88, 96, 103, 111, 119, 128, 137, 146, 155, 164, 179
TG-07	5	129, 138, 147, 156, 165, 178
TG-08	11	7, 15, 26, 29, 37, 45, 58, 60, 69, 82, 90, 98, 101, 109, 122
TG-09	5	131, 140, 149, 158, 167, 176
TG-10	1	10
TG-11	8	8, 61, 70, 83, 91, 99, 100, 108
TG-12	7	16, 20, 27, 28, 36, 44, 59
TG-13	6	135, 144, 153, 162, 171, 172
TG-14	2	11, 124, 125
TG-15	5	134, 143, 152, 161, 170, 173
TG-16	6	121, 130, 139, 148, 157, 166, 177
TG-17	5	133, 142, 151, 160, 169, 174
TG-18	5	132, 141, 150, 159, 168, 175
TG-19	1	123